Laboratorium 5 - Bezpieczeństwo serwera WWW

3 zadania po 1 pkt. 90 minut (2 × 45). Plan: 10 minut wprowadzenia, 20 + 20 + 25 minut na zadania, 15 minut na raport i oddanie. Środowisko z `START.md` przygotuj przed zajęciami. Reguły dostępu i kod CGI napisz samodzielnie. Dostarczony kontener zawiera Apache 2.4, Python 3 i powłokę sh.

Dozwolone: ISOD, dokumentacja, własne notatki i własny wcześniej napisany kod. Podczas zajęć wyłącz czaty i podpowiedzi LLM. Przy odbiorze wyjaśniasz konfigurację i kod. Pracuj na lokalnym serwerze z pakietu, pod adresem `http://127.0.0.1:8080`.

Uruchomienie i sprawdzanie

Wszystkie polecenia wykonuj w katalogu `pliki-dla-studentow`. Uruchom `docker compose up -d web`. Reguły wpisuj do `konfiguracja/dostep.conf`, używając sekcji `<Directory>` z pełnymi ścieżkami w kontenerze. Nie zmieniaj `httpd.conf`, Dockerfile ani danych wejściowych. Nie używaj `.htaccess` ani starych dyrektyw `Order`, `Allow`, `Deny`.

Po zmianie konfiguracji wykonaj `docker compose exec web httpd -t`, a po wyniku `Syntax OK`: `docker compose restart web`. Logi: `docker compose logs --tail 30 web`. Przykładowy odczyt odpowiedzi: `curl -i http://127.0.0.1:8080/materialy/`. W Windows użyj `curl.exe`. Sprawdzaj pełne odpowiedzi GET, z końcowym `/` dla katalogów.

Pomoc i zapis wyników

Cele, test gotowości i wskazówki: `pliki-dla-studentow/PRZEWODNIK.md`. Raport ma jedną stronę: zwięzłe wyniki i wnioski. Długie polecenia, ładunki i logi możesz zapisać w `dowody.md` w repozytorium, wskazując sekcje w raporcie. Skracaj tokeny; nie zapisuj haseł ani kluczy prywatnych.

Zadanie 1 - Dostęp do katalogów (20 min, 1 pkt)

1. Przed zmianami sprawdź cztery adresy: `/materialy/`, `/materialy/notatka.txt`, `/wewnetrzne/`, `/wewnetrzne/plan.txt`. Zapisz kody HTTP i sprawdź, gdzie widoczna jest lista plików.
2. Dla katalogu `/usr/local/apache2/htdocs/materialy` wyłącz listowanie. Dostęp do pliku `notatka.txt` przez jego pełny URL ma nadal działać. Nie dodawaj pliku indeksowego i nie usuwaj danych.
3. Dla `/usr/local/apache2/htdocs/wewnetrzne` zablokuj cały dostęp przez HTTP, także do `plan.txt` o znanej nazwie.
4. Sprawdź składnię, zrestartuj serwer i powtórz cztery żądania. W logach wskaż jeden wpis potwierdzający odmowę dostępu.

W raporcie: tabela czterech adresów z kodami przed i po zmianie, jeden wpis z logu oraz jedno zdanie wyjaśniające różnicę między wyłączeniem listowania a blokadą dostępu.

Zadanie 2 - Katalog dostępny na hasło (20 min, 1 pkt)

1. Utwórz konto `student` z własnym hasłem ćwiczeniowym: `docker compose run --rm --no-deps narzedzia -cB /auth/uzytkownicy student`. Hasło podaj interaktywnie. Plik powstanie w `auth/`, poza katalogiem dokumentów WWW. Opcji `-c` używa się przy tworzeniu bazy; ponowne użycie zastępuje jej zawartość.
2. W `dostep.conf` skonfiguruj HTTP Basic dla `/usr/local/apache2/htdocs/panel`. Użyj nazwy obszaru `Laboratorium 5` oraz pliku haseł `/auth/uzytkownicy`. Dostęp mają poprawnie uwierzytelnieni użytkownicy z tej bazy.
3. Po sprawdzeniu składni i restarcie przetestuj `/panel/raport.txt`: bez danych logowania, z błędnym hasłem oraz z poprawnym hasłem. Przy `curl -i -u student http://127.0.0.1:8080/panel/raport.txt` program poprosi o hasło. Przy odpowiedzi bez logowania odnotuj nagłówek `WWW-Authenticate`.

4. Sprawdź, że publiczna strona `/` nadal działa bez logowania. Nie wpisuj hasła ani zawartości bazy do raportu i repozytorium.

W raporcie: kody HTTP z czterech prób, wartość `WWW-Authenticate` bez logowania i jedno zdanie o tym, dlaczego Basic przez zwykłe HTTP nie chroni hasła w transmisji. Na tych zajęciach używamy wyłącznie lokalnego serwera i hasła ćwiczeniowego; HTTPS będzie tematem laboratorium 9.

Zadanie 3 - Uprawnienia programu CGI (25 min, 1 pkt)

1. Napisz własny skrypt `cgi-bin/uprawnienia.cgi` w Pythonie 3 albo sh. W pierwszym wierszu podaj odpowiednio `#!/usr/bin/python3` albo `#!/bin/sh`. Skrypt ma zwracać `Content-Type: text/plain; charset=utf-8`, pustą linię i tekstową odpowiedź. Zapisz plik z końcami wierszy LF.

2. W odpowiedzi wypisz efektywny UID i GID procesu. Następnie spróbuj odczytać oba pliki: `/lab-data/ogolny.txt` i `/lab-data/poufny.txt`. Dla każdego pokaż treść albo komunikat o odmowie odczytu. Obsłuż odmowę w programie, aby nadal powstała poprawna odpowiedź HTTP. Nie uruchamiaj dodatkowych poleceń otrzymanych od użytkownika.

3. Wykonaj `docker compose up -d --build web`. Obraz kopiuje napisane CGI i nadaje mu prawo wykonania. Otwórz `/cgi-bin/uprawnienia.cgi`. W kontenerze sprawdź właścicieli i prawa: `docker compose exec web ls -ln /lab-data/`. Porównaj je z UID/GID wypisanym przez CGI. Nie zmieniaj praw danych ani użytkownika serwera.

4. Zabezpiecz katalog `/usr/local/apache2/cgi-bin` mechanizmem Basic z zadania 2. Po sprawdzeniu składni i restarcie ponów żądanie: bez logowania oraz z poprawnym hasłem. Porównaj UID/GID i wyniki odczytów z tymi sprzed włączenia Basic.

W raporcie: UID/GID, właściciele i prawa obu plików, wyniki odczytu oraz kody HTTP przed Basic, bez logowania po Basic i z poprawnym hasłem. Dodaj jedno zdanie: dlaczego zalogowanie do serwera WWW nie daje CGI praw administratora systemu.

Oddanie - jeden plik raportu do końca zajęć

Oddaj **jeden plik w formacie tekstowym**, np. **TXT, MD lub PDF z tekstem**. **Nazwa pliku jest dowolna. Raport należy oddać do końca zajęć** w miejscu wskazanym przez prowadzącego. Raport do jednej strony zawiera imię i nazwisko, numer indeksu, link do repozytorium GitHub, identyfikator commitu oraz wyniki i krótkie odpowiedzi z trzech zadań. Uzupełniaj go podczas pracy; oddaj również ukończone części.

W repozytorium umieść własny `dostep.conf`, kod CGI i README z uruchomieniem. Możesz dołączyć pliki środowiska z pakietu. Repozytorium musi być dostępne dla prowadzącego. Baza haseł pozostaje lokalna. Nie oddawaj ZIP-a, osobnych załączników z kodem ani samych zrzutów ekranu.

Punktacja

Za każde zadanie: **0,50 pkt** za działającą własną konfigurację lub kod w repozytorium, **0,25 pkt** za wymagane wyniki w raporcie i **0,25 pkt** za poprawne wyjaśnienie. Łącznie **3 pkt**. Instalacja środowiska nie jest osobnym zadaniem punktowanym.